

Normes et conformité

1. Objectif

Le projet Triply intègre dès sa conception les exigences réglementaires et les bonnes pratiques en matière de protection des données et de sécurité des systèmes d'information.

L'objectif est de :

- garantir la confidentialité des données utilisateur
- assurer la conformité légale (RGPD)
- sécuriser les échanges et le stockage des données
- adopter une approche privacy by design dès le MVP

2. Réglementation applicable

Le projet respecte le cadre légal suivant :

Règlement Général sur la Protection des Données (RGPD – UE 2016/679)

- Entré en application : 25 mai 2018
- Applicable à toute application traitant des données personnelles en Europe

Principaux droits garantis :

- droit d'accès
- droit de rectification
- droit à l'effacement
- droit à la portabilité

3. Principes RGPD appliqués

Minimisation des données

Seules les données strictement nécessaires sont collectées :

- réponses au questionnaire
- préférences utilisateur
- localisation (si activée)

Finalité

Les données sont utilisées uniquement pour :

- générer des recommandations personnalisées
- améliorer l'expérience utilisateur

Consentement

- consentement explicite requis pour certaines données (ex : géolocalisation)
- possibilité de retrait à tout moment

Sécurité

- chiffrement des données sensibles
- sécurisation des API
- contrôle des accès

4. Données traitées

Donnée	Type	Traitement
Profil utilisateur	Personnel	Stocké en base
Historique	Comportemental	Pseudonymisé
Localisation	Sensible	Consentement requis
Données chatbot	Texte	Anonymisées / non persistées

5. IA et protection des données

Le système d'intelligence artificielle est conçu selon une approche privacy by design :

- aucune donnée personnelle identifiable n'est directement envoyée au modèle
- utilisation de données pseudonymisées (UUID)
- filtrage des informations avant traitement par le LLM

L'IA exploite uniquement :

- des préférences
- des données agrégées
- des informations non sensibles

6. Bonnes pratiques techniques

Le projet respecte plusieurs standards de développement :

- architecture API REST (structuration des échanges)
- sécurisation des endpoints
- séparation des responsabilités (backend / IA)
- gestion des erreurs et validation des données

7. Normes et référentiels de sécurité

Le projet s'appuie sur des standards reconnus :

ISO/IEC 27001

Norme internationale pour la gestion de la sécurité de l'information :

- gestion des risques
- protection des données
- gouvernance sécurité

OWASP Top 10

Référentiel des principales vulnérabilités web :

- injections
- failles d'authentification
- exposition de données sensibles

Utilisé pour sécuriser les applications web

8. Mesures mises en place

- pseudonymisation des utilisateurs (UUID)
- limitation de la durée de conservation des données
- sécurisation des communications (HTTPS)
- suppression des données sur demande
- contrôle des accès aux ressources

9. Sources officielles

Réglementation

- RGPD (UE 2016/679)

<https://eur-lex.europa.eu/eli/reg/2016/679/oj>

- CNIL (Commission Nationale de l'Informatique et des Libertés)

<https://www.cnil.fr>

Guides et bonnes pratiques

- Sécurité des données (CNIL)

<https://www.cnil.fr/fr/securite-des-donnees>

Normes et sécurité

- ISO/IEC 27001

<https://www.iso.org/isoiec-27001-information-security.html>

- OWASP Top 10

<https://owasp.org/www-project-top-ten/>